

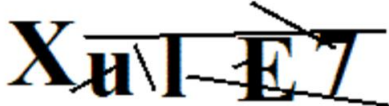
110 年度初級資訊安全工程師能力鑑定試題

科目 2：資訊安全技術概論

考試日期：110 年 11 月 20 日

第 1 頁，共 9 頁

單選題 50 題 (佔 100%)

D	1. 關於網路型入侵偵測系統 (Network Intrusion Detection System, NIDS)，下列敘述何者正確？ (A) 安裝後對於網路流量的影響很大 (B) 安裝後可以保護所有電腦不被入侵 (C) 其資料來源是作業系統、應用程式或網路登入/登出紀錄 (Log) (D) 若流量 (Traffic) 太高，可能會影響攻擊偵測準確度
A	2. 下列何者較常被採用來執行分散式阻斷服務 (Distributed Denial-of-Service, DDoS) 攻擊？ (A) UDP 封包攻擊 (B) TCP 封包攻擊 (C) HTTP 封包攻擊 (D) SQL 封包攻擊
D	3. 封包過濾型防火牆是判別封包的 IP 與埠號 (port)，主要是防禦開放式系統互聯模型 (Open System Interconnection Model, OSI) 中第幾層之攻擊？ (A) 1 (B) 2 (C) 3 (D) 4
C	4. 在網頁登入時，常常在帳號密碼輸入的欄位之下，還要求如附圖所示輸入其他驗證資訊，請問此機制為下列何者？  請輸入： 驗證登入 (A) 詢問握手認證協議 (Challenge-Handshake Authentication Protocol, CHAP) (B) 晶片卡驗證 (Smart Card Authentication) (C) 全自動區分電腦和人類的公開圖靈測試 (Completely Automated Public Turing test to tell Computers and Humans Apart, CAPTCHA) (D) 簡訊服務驗證 (SMS Authentication)
C	5. 關於網路位址轉換 (Network Address Translation, NAT)，下列敘述何者較「不」正確？

110 年度初級資訊安全工程師能力鑑定試題

科目 2：資訊安全技術概論

考試日期：110 年 11 月 20 日

第 2 頁，共 9 頁

	(A) 可減少公有 IP (Public IP) 位址使用數量 (B) 可隱藏內部 IP 位址 (C) 可防止暴力攻擊 (Brute-Force Attack) (D) 內部網路中使用私有 IP 位址 (Private IP)
C	6. 下列何種攻擊「不」會造成系統處理效率下降？ (A) 死亡偵測攻擊 (Ping-of-Death Attack) (B) 分割重組攻擊 (Teardrop Attack) (C) 中間人攻擊 (Man-In-The-Middle Attack) (D) 分散式攻擊 (Distributed Attack)
D	7. 關於 Tor 網路，下列敘述何者「不」正確？ (A) Tor 是一個實現匿名通信的自由軟體 (B) Tor 可以保障用戶的個人隱私，以及不受監控地進行秘密通信的自由和能力 (C) Tor 常被使用來連線至暗網 (D) 使用 Tor 連線，網路瀏覽的速度不會減慢
D	8. 下列何種攻擊方式的主要目的是為了讓使用者無法進行服務的存取？ (A) 中間人攻擊 (Man-In-The-Middle Attack) (B) 資料隱碼攻擊 (SQL Injection) (C) 社交工程攻擊 (Social Engineering) (D) 阻斷服務攻擊 (Denial-of-Service Attack)
B	9. 請問 TCP/IP 通訊協定中之應用層是合併開放式系統互聯模型 (Open System Interconnection Model, OSI) 的哪幾層？ (A) 應用層 (Application Layer)、傳輸層 (Transport Layer)、網路層 (Network Layer) (B) 應用層 (Application Layer)、表達層 (Presentation Layer)、會議層 (Session Layer) (C) 應用層 (Application Layer)、傳輸層 (Transport Layer)、會議層 (Session Layer) (D) 應用層 (Application Layer)、表達層 (Presentation Layer)、網路層 (Network Layer)
C	10. 關於 IPSec，下列敘述何者較「不」正確？ (A) IPSec 是 IP Security 的縮寫，是運用在網路層的保護機制 (B) IPSec 提供資料加密、資料完整性、以及身份認證 (Authentication) (C) IPSec 將整個封包 (IP 標頭和資料本身) 進行加密保護 (D) IPSec 重新封裝後的封包可以正確的在既有網路上傳送，不會因為標頭被更改而受到影響

110 年度初級資訊安全工程師能力鑑定試題

科目 2：資訊安全技術概論

考試日期：110 年 11 月 20 日

第 3 頁，共 9 頁

D	11. 下列何種協定負責在 TCP/IP 通訊協定中提供定址與路由之任務？ (A) 應用層 (Application Layer) (B) 表達層 (Presentation Layer) (C) 傳輸層 (Transport Layer) (D) 網路層 (Network Layer)
D	12. 關於 SSL 與 TLS，下列敘述何者較「不」正確？ (A) TLS 協定的發行時間較 SSL 晚 (B) 兩者都是加密協議，用於從客戶端到伺服器、電腦或應用程式數據傳輸的加密和驗證 (C) HTTPS 結合了處理資料傳輸的 HTTP 和處理資料加密的 SSL/TLS (D) TLS 3.0 是目前資料進行傳輸過程中，大多數設備和瀏覽器所支援的
C	13. 小明利用 ssh 命令從主機 A 首次成功的連接至主機 B，請問下列何種 ssh 檔案將會被更新？ (A) 主機 B 上的 ~/.ssh/authorized_keys 檔案 (B) 主機 A 上的 ~/.ssh/authorized_keys 檔案 (C) 主機 A 上的 ~/.ssh/known_hosts 檔案 (D) 主機 B 上的 ~/.ssh/known_hosts 檔案
A	14. 請問永恆之藍 (EternalBlue) 弱點是基於下列何種機制所產生的？ (A) Windows SMB (B) Windows Kerberos (C) Windows RDP (D) Windows UAC
D	15. 下列何項新廠區的網路規劃「不」屬於資安考量？ (A) 安裝 3 台接取網路交換器並設定 3 個 VLANs 且分為 3 個子網段 (subnet) 供不同部門使用 (B) 使用 VPN 閘道器建立總廠與新廠的安全傳輸網路 (C) 在新生產線佈署工規交換器，並且設定獨立的 VLAN 與子網段連接資料採集與監視系統 (Supervisory Control and Data Acquisition, SCADA)，自動化生產與控制系統設備 (D) 建置網路路由器提供網路流量交換
B	16. 關於使用者帳戶控制 (User Account Control, UAC)，下列敘述何者較「不」正確？ (A) 保護或提醒管理員用戶免受軟體組件執行的惡意提權行為 (B) 訪客通常會以最大的使用者權限執行 (C) 通過限制應用軟體對系統層級的存取，從而改進 Windows 作業

110 年度初級資訊安全工程師能力鑑定試題

科目 2：資訊安全技術概論

考試日期：110 年 11 月 20 日

第 4 頁，共 9 頁

	系統的安全性 (D) 設計概念為消除不必要的提高許可權
B	17. 下列何者屬於密碼潑灑 (Password Spraying) 攻擊？ (A) 蒐集常用的密碼放入字典，嘗試登入系統 (B) 用單一弱密碼，嘗試登入系統 (C) 使用已外洩的帳號與密碼的各種組合，嘗試登入系統 (D) 使用可能各種密碼組合，嘗試登入系統
C	18. 根據開放網路軟體安全計畫 (Open Web Applications Security Project, OWASP) 研究報告所指出網頁十大安全性弱點利用與攻擊中，為了防範常見的跨網站指令碼攻擊 (Cross-Site Scripting, XSS)、注入攻擊 (Injection Flaws) 等，應採用下列何種策略較佳？ (A) 整個網站均採用 TLS 傳輸 (B) 採用嚴謹的驗證方式 (C) 網頁程式中需做好輸入及輸出的檢查工作 (D) 實施端點安全性檢查
B	19. 使用者瀏覽網頁時，執行攻擊者插入到網頁中 HTML 或 Script 的指令，此狀況是遭受到下列何種攻擊？ (A) 資料隱碼攻擊 (SQL Injection) (B) 跨網站指令碼攻擊 (Cross-Site Scripting, XSS) (C) 跨網站請求偽照攻擊 (Cross-Site Request Forgery, CSRF) (D) 搜尋引擎攻擊 (Google Hacking)
C	20. 關於資料隱碼攻擊 (SQL Injection)，下列何者較「無」防禦效果？ (A) 使用參數化語句 (B) 強化對輸入值的驗證 (C) 使用單一登入 (Single Sign-On) (D) 使用安全的 API
B	21. 規劃縱深防禦 (Defense in Depth) 時，常會採用多種不同面向的管控措施 (Controls)，下列何者屬於偵測手段 (Detection)？ (A) 防火牆 (Firewall) (B) 入侵偵測系統 (IDS) (C) 病毒與垃圾郵件過濾閘道系統 (D) 虛擬私有網路 (VPN)
B	22. 若程式在源碼檢測時，發現存在可能遭受到有心人士的中間人攻擊 (Man-In-The-Middle Attack, MITM) 的漏洞，下列何者較可能為存在的主要問題？ (A) 無稽核 (Lack of Auditing)

110 年度初級資訊安全工程師能力鑑定試題

科目 2：資訊安全技術概論

考試日期：110 年 11 月 20 日

第 5 頁，共 9 頁

	(B) 無憑證檢查 (Lack of Certificate Verification) (C) 無邊界檢查 (Lack of Boundary Check) (D) 無輸入驗證 (Lack of Input Validation)
D	23. 關於跨網站請求偽造攻擊 (Cross-Site Request Forgery, CSRF)，下列何種防禦方式較有效？ (A) 輸入參數黑名單過濾 (Black List) (B) 輸入參數白名單過濾 (White List) (C) 輸入參數長度過濾 (Length Filter) (D) 使用全自動區分電腦和人類的公開圖靈測試 (Completely Automated Public Turing test to tell Computers and Humans Apart, CAPTCHA)
C	24. 下列何者「不」是 Source Code Review 軟體？ (A) FortifySCA (B) Checkmarx (C) BurpSuite (D) SonarQube
D	25. 關於入侵偵測系統 (Intrusion Detection System, IDS) 部署，下列敘述何者較正確？ (A) 需部署於防火牆前端以達最佳之功效 (B) 可部署於組織任一節點中，只要處於 Sniffer mode 即可 (C) 僅需搜集鄰近節點防火牆資訊即可觀察整體網路流量 (D) 盡可能地收集整體環境進出之流量，以達最大之功效
B	26. 未適當處理程式產生的詳細錯誤訊息和未處理的異常，較有可能導致下列何種威脅？ (A) 偽裝 (Spoofing) (B) 資訊洩露 (Information Disclosure) (C) 篡改 (Tampering) (D) 否認 (Repudiation)
C	27. 在網站弱點檢測報告中，發現系統存在跨網站指令碼 (Cross-Site Scripting, XSS) 及開放式重定向 (Open Redirect) 攻擊問題，可以採取下列何者方案進行修補？ (A) XSS 可以透過過濾此符號“<”，即可根治 (B) Open Redirect 可以採用圖像式驗證即可根治 (C) HTML.Encode 是可以解決 XSS 的一種方法 (D) XSS 可以採用 Prepared Statement 解決
B	28. 關於防毒軟體 (Antivirus)，下列敘述何者較「不」正確？

110 年度初級資訊安全工程師能力鑑定試題

科目 2：資訊安全技術概論

考試日期：110 年 11 月 20 日

第 6 頁，共 9 頁

	(A) 無法偵測所有攻擊 (B) 非 Windows 系統無需安裝防毒軟體 (C) 常使用特徵 (Signature) 比對來偵測惡意程式 (D) 可監視作業系統的可疑活動與應用程式的行為
D	29. 下列何者較「不」是在軟體逆向工程動態分析時會使用到的手法？ (A) 設定中斷點 (B) 顯示堆疊 (stack) 內容 (C) 單步執行 (D) 程式碼重構
D	30. 讓惡意程式或可疑檔案在虛擬化的控制環境當中執行，隔離不信任的檔案，避免對系統造成損害，此為下列何種分析方式？ (A) 動態分析 (B) 靜態分析 (C) 黑箱分析 (D) 沙盒分析
A	31. 下列何者較「不」是 SYN 洪水攻擊 (SYN Flood) 的防禦方式？ (A) 利用防火牆阻擋所有 TCP 連線 (B) 增加 Backlog Queue 的數量 (C) 重置最舊的 Half-Open TCP 連線 (D) 使用 SYN Cookie
C	32. 只有在第一次備份時做完整備份，而之後每次備份時，只從上次備份至目前有改變的檔案進行備份，此為下列何種備份方式？ (A) 完整備份 (Full Backup) (B) 差異備份 (Different Backup) (C) 增量備份 (Incremental Backup) (D) 選擇式備份 (Selective Backup)
C	33. 關於資料備份之原則，下列敘述何者較「不」正確？ (A) 完整及正確之備份資料 (B) 備份資料時須注意實體安全 (C) 資料備份時應挑選未加密之資料進行備份 (D) 資料備份維持三代以上
C	34. 下列何者較「不」屬保護資料機密性的範圍？ (A) 網站因資料隱碼攻擊 (SQL Injection) 弱點導致遭駭客取得員工資料 (B) 購物系統被駭客入侵，造成客戶資料外洩 (C) 訂票系統因大量會員同時登入，系統當機而無法提供服務

110 年度初級資訊安全工程師能力鑑定試題

科目 2：資訊安全技術概論

考試日期：110 年 11 月 20 日

第 7 頁，共 9 頁

	(D) 學校教學系統遭人入侵而公布學生考試分數
C	35. 關於強化異地存放的備份資料的「可用性」的作法，下列敘述何者較正確？ (A) 將備份資料進行加密 (Encrypt) (B) 將備份資料進行雜湊 (Hash) 函數計算 (C) 將備份資料進行定期回復 (Restore) 測試 (D) 將備份資料進行壓縮 (Compress)
A	36. 若資料持續不斷增加，則差異備份、增量備份、完整備份三種備份方式的備份速度，「由慢到快」依次為下列何者？ (A) 完整備份、差異備份、增量備份 (B) 差異備份、增量備份、完整備份 (C) 增量備份、差異備份、完整備份 (D) 完整備份、增量備份、差異備份
B	37. 若某公司以使用者資料報協定 (User Datagram Protocol, UDP) port 514 的方式，遠端蒐集 Syslog 進行日誌留存，下列敘述何者較正確？ (A) 遠端蒐集之日誌，無法作為有效證據 (B) 網路流量大時，有可能遺失封包 (資料) (C) Syslog 無需考量加密即可保護資料傳輸之安全 (D) 遠端蒐集之日誌，存放時不應加密，以免破壞資料的正確性
D	38. 要求相關的資訊系統、網路設備須有一致性的同步時脈 (Clock Synchronization)，其主要的目的為下列何者？ (A) 確保作業系統的機密性 (B) 防範資料的漏失 (C) 避免被分散式阻斷服務攻擊 (Distributed Denial-of-Service, DDoS) (D) 確保稽核日誌的準確性，以便紀錄事件與生成證據
C	39. 分析集中收容的不同設備之日誌時，常會發生不同設備之日誌格式、命名方式不同之分析難題，此時需要進行下列何種處理？ (A) 去識別化 (De-identification) (B) 初始化 (Initialization) (C) 正規化 (Normalization) (D) 最佳化 (Optimization)
D	40. 「留存系統、網路日誌」是為了保護下列何種特性？ (A) 機密性 (Confidentiality) (B) 可用性 (Availability) (C) 可靠性 (Reliability)

110 年度初級資訊安全工程師能力鑑定試題

科目 2：資訊安全技術概論

考試日期：110 年 11 月 20 日

第 8 頁，共 9 頁

	(D) 不可否認性 (Non-Repudiation)
C	41. 關於日誌的管理，下列敘述何者較「不」正確？ (A) 選擇適當的整合式日誌管理工具，並且測試確認是否能快速查詢分析 (B) 可考慮將有機敏資料的日誌加密儲存，避免資料遭到竄改 (C) 須將系統的所有稽核日誌全部啟動與儲存 (D) 應定義事件分類，以有效分析
B	42. 駭客入侵雲端服務供應商，再以此為跳板入侵使用者竊取資料，此為下列何者行為？ (A) 封包監聽 (B) 雲端跳躍 (C) 阻斷服務攻擊 (D) 社交工程
D	43. 下列何者「不」是由美國國家標準技術研究院 (National Institute of Standards and Technology, NIST) 所定義的雲端運算的五項關鍵特徵之一？ (A) 可量測的服務 (B) 快速且彈性的架構 (C) 廣泛的網路存取方式 (D) 資源調配皆由供應商的人員協助
D	44. 使用行動裝置的近距離無線通訊 (Near Field Communication, NFC) 功能進行行動支付或資料交換時，較「無」需防範下列何種攻擊？ (A) 中間人攻擊 (Man-In-The-Middle Attack) (B) 竊聽 (Sniffing) (C) 重送攻擊 (Replaying Attack) (D) 通行碼暴力破解 (Password Brute Force Attack)
C	45. 關於強化行動裝置安全，下列敘述何者較「不」安全？ (A) 設定螢幕鎖定需輸入密碼或指紋後方能使用 (B) 當收到系統安全性更新的提醒即進行更新 (C) 啟動無線區域網路自動連線機制以避免連接不受信任的 AP (D) 避免使用不信任的第三方 APP
B	46. 下列何者較可以避免行動裝置連接 Wifi 時，遭受到中間人攻擊 (Man-In-The-Middle Attack, MITM) ？ (A) 設定開機密碼鎖 (B) 連線使用加密 VPN 連線服務 (C) 限制連線 Wifi 之速率

110 年度初級資訊安全工程師能力鑑定試題

科目 2：資訊安全技術概論

考試日期：110 年 11 月 20 日

第 9 頁，共 9 頁

	(D) 可連線不具身分認證機制的 Wifi 熱點或服務
A	47. 關於行動裝置上運用代碼技術 (Tokenization) 行動支付方式的安 全，下列敘述何者正確？ (A) 駭客無法由代碼去推算使用者原本的卡號 (B) 以手機本身的 Secure Element 儲存 Tokenization 是不安全的 (C) 手機遺失時，儲存在手機的信用卡卡號仍會被取得 (D) 應越獄 (Tethered Jailbreak) 取得手機權限來管理較安全
D	48. 下列何者「不」是在物聯網中，駭客利用連網智慧家電所採用之安全 性較不高的通訊協定來進行的攻擊手法？ (A) 中間人攻擊 (Man-In-The-Middle Attack, MITM) (B) TCP/IP 劫持 (TCP/IP Hijacking) (C) 重播攻擊 (Replay) (D) 垃圾搜尋攻擊 (Dumpster Diving)
D	49. 關於物聯網安全，下列敘述何者「不」正確？ (A) 應購買具有安全認證之物聯網設備 (B) 應有專人定期檢查維護 (C) 使用其他資安設備 (如防火牆) 保護物聯網設備 (D) 使用預設帳號密碼與相關設定，以確保物聯網設備正常運作
A	50. 物聯網裝置組成的網路中，有兩個距離遙遠的惡意節點建立私有的通 訊管道互相傳送訊息，可形成下列何種攻擊？ (A) 蟲洞攻擊 (B) 分割攻擊 (C) 黑洞攻擊 (D) 黑函攻擊